

Standards & Methodologies

MITRE ATT&CK, Atomic Red Team, OWASP, NIST, OSSTMM, PTES & ISSAF — Full Explanation With Examples

Prepared for: Muhammad Shafiq Goraya

Track: Red Team / Penetration Testing

Style: Plain explanations, real-world examples, no quiz format

Covers: Every major penetration testing standard and framework referenced in the lecture, expanded with additional detail and real-world context, plus a beginner roadmap for CTFs and bug bounty

Methodology

MITRE ATT&CK

Atomic Red Team

OWASP Top 10

OWASP WSTG

NIST SP 800-53

NIST SP 800-115

OSSTMM

PTES

ISSAF

WHAT'S INSIDE

- Lesson 1 — Why penetration testing standards matter
- Lesson 2 — MITRE ATT&CK (expanded)
- Lesson 3 — Atomic Red Team (expanded)
- Lesson 4 — OWASP Top 10 (expanded)
- Lesson 5 — OWASP Web Security Testing Guide / WSTG (expanded)
- Lesson 6 — NIST SP 800-53 (expanded)
- Lesson 7 — NIST SP 800-115 (expanded)
- Lesson 8 — OSSTMM (expanded)
- Lesson 9 — PTES (expanded)
- Lesson 10 — ISSAF
- Complete Comparison Table + Memory Tricks
- Beginner Roadmap — Which standard to learn first for CTF & Bug Bounty

Lesson 1 · Why Do We Need Penetration Testing Standards?

Many beginners get excited and start hacking immediately. But without a methodology, they forget important things during the penetration test.

Imagine This — Building Inspection

Student A walks randomly: checks one room, skips another, forgets the roof, never checks the basement. Result: the building inspection is incomplete.

Student B has a checklist: check entrance, check windows, check roof, check basement, write report. Result: nothing important is missed.

Penetration testing works the same way. A beginner often just runs Nmap, then Gobuster, then SQLMap, and thinks "I hacked it!" But he may have forgotten DNS enumeration, email security, authentication testing, business logic testing, and reporting. That means the penetration test is not complete.

What is a Standard or Methodology?

A methodology is simply a step-by-step guide that tells you what to test and in what order — think of it like a recipe or a checklist. Instead of guessing, you follow a proven process:

Planning

Reconnaissance

Scanning

Enumeration

Exploitation

Privilege Escalation

Post Exploitation

Reporting

When you follow this order, you are less likely to miss something.

Why Is This Important?

Real-World Example

Imagine your client pays you \$10,000 for a penetration test. You forget to test the login page. Later, a hacker steals customer data through that login page. The client asks: "Why didn't you find this?" You cannot say "I forgot." That is why professionals use standards and methodologies — they reduce mistakes and help produce consistent, thorough assessments.

Testing a Bank — With vs Without a Methodology

Without a methodology: SQL Injection checked, Directory Enumeration checked, but Authentication Testing, Session Management, and API Testing are all forgotten. The report is incomplete.

With a methodology: Planning, Recon, Scanning, Authentication, Authorization, Input Validation, Business Logic, and Reporting are all checked. Everything important is covered.

Key Points to Remember

- A methodology is a step-by-step process.
- It helps you avoid missing important tests.
- Professional penetration testers always follow a methodology.
- Standards improve the quality and consistency of penetration tests.

PenTest+ Exam Tip

Why are penetration testing methodologies important? Because they provide a structured process that reduces the chance of missing important security tests.

Lesson 2 · MITRE ATT&CK

Easy Meaning

MITRE ATT&CK = "The Hacker Encyclopedia." A database of real-world attacker tactics and techniques.

Additional Research — What MITRE ATT&CK Actually Contains

MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) is a free, globally accessible knowledge base maintained by the MITRE Corporation, built from real observed cyberattacks. It is organized as a matrix: the columns are **Tactics** — the attacker's goal at each stage, such as Initial Access, Execution, Persistence, Privilege Escalation, Defense Evasion, Credential Access, Discovery, Lateral Movement, Collection, Command and Control, Exfiltration, and Impact. Under each tactic are **Techniques** and **Sub-techniques** — the specific methods attackers use to achieve that goal (for example, "Phishing" under Initial Access, or "Pass the Hash" under Lateral Movement). There are separate matrices for Enterprise (Windows, macOS, Linux, cloud), Mobile, and ICS (Industrial Control Systems) environments.

Why Does It Matter?

Instead of guessing how a real attacker might move through a network, a penetration tester or red teamer can look up documented, real-world techniques and simulate them accurately. This is especially useful for red teaming, threat intelligence, and building detection rules that a Blue Team (defenders) can test against.

Example for Understanding

Imagine a red team is hired to simulate a ransomware group. Instead of inventing attack steps randomly, they look up MITRE ATT&CK to see the actual techniques that group is known to use — for example, a specific phishing technique for Initial Access and a specific tool for Lateral Movement. This makes the simulation realistic and useful for the client's defense team.

Best For

Advanced CTFs, Red Teaming, Active Directory attack chains, understanding privilege escalation, persistence, and lateral movement.

Lesson 3 · Atomic Red Team

Easy Meaning

Atomic Red Team = "Practice Scripts." It lets you safely simulate the techniques described in MITRE ATT&CK.

Additional Research — How It Actually Works

Atomic Red Team is an open-source library created by Red Canary, made up of small, standalone tests called "atomic tests," each mapped directly to a specific MITRE ATT&CK technique or sub-technique. Instead of running a full, complex attack chain, a tester can execute one small, focused test — for example, a single atomic test that mimics a specific credential-dumping technique — inside a safe lab environment, then check whether security tools (like an EDR or SIEM) actually detected it.

Example for Understanding

Imagine MITRE ATT&CK is the encyclopedia entry describing a "Pass the Hash" attack. Atomic Red Team is the actual short script you can run in your own lab to perform a safe, controlled version of that exact technique — so you can see it in action and test whether your defenses catch it.

Best For

Learning MITRE ATT&CK hands-on, validating detection capability, and building toward Red Team Operations. Best learned after you already understand MITRE ATT&CK conceptually.

Lesson 4 · OWASP Top 10

Easy Meaning

OWASP Top 10 = "Top Web Risks." A list of the 10 most critical security risks facing web applications today.

Additional Research — What's Actually on the List

OWASP (Open Web Application Security Project) publishes this list periodically based on real-world data and community input. The most recent well-known version (2021) lists categories such as: Broken Access Control, Cryptographic Failures, Injection (including SQL Injection and XSS), Insecure Design, Security Misconfiguration, Vulnerable and Outdated Components, Identification and Authentication Failures, Software and Data Integrity Failures, Security Logging and Monitoring Failures, and Server-Side Request Forgery (SSRF). It is intentionally short and awareness-focused — it's meant to be the starting point, not the entire methodology.

Example for Understanding

Think of the OWASP Top 10 like a "most wanted" poster for web vulnerabilities. It doesn't tell you step-by-step how to test everything about a website — it tells you which categories of vulnerabilities are most dangerous and most common, so you know where to focus your attention first.

Best For

Building awareness of the most critical web risks, prioritizing what to look for first in a bug bounty program, and communicating vulnerability severity to non-technical stakeholders.

Lesson 5 · OWASP Web Security Testing Guide (WSTG)

Easy Meaning

OWASP WSTG = "Testing Guide." A detailed, step-by-step guide for testing web application security.

Additional Research — What the Guide Actually Covers

While the OWASP Top 10 tells you *what* the biggest risks are, the WSTG tells you *how* to actually test for them and much more. It is organized into categories including Information Gathering, Configuration and Deployment Management Testing, Identity Management Testing, Authentication Testing, Authorization Testing, Session Management Testing, Input Validation Testing, Error Handling, Cryptography Testing, Business Logic Testing, Client-Side Testing, and API Testing. Each category includes specific test cases with example steps and payloads.

Example for Understanding

If OWASP Top 10 is the "most wanted poster," the WSTG is the full detective's manual — it walks you through exactly how to investigate each type of vulnerability, step by step, including what tools to use and what a positive result looks like.

Best For

Bug bounty hunting, web application penetration testing, and CTF web challenges — this is one of the most practically useful frameworks for a beginner focused on web security.

Lesson 6 · NIST SP 800-53

Easy Meaning

NIST SP 800-53 = "Security Controls." A catalog of security and privacy controls, mainly used by U.S. federal systems and organizations that need to meet compliance requirements.

Additional Research — What It Actually Is

NIST (National Institute of Standards and Technology) SP 800-53 is not a penetration testing methodology by itself — it is a large catalog of security and privacy controls organized into families such as Access Control, Audit and Accountability, Incident Response, and System and Information Integrity. One specific control, **CA-8 "Penetration Testing,"** directly requires organizations to conduct penetration testing as part of their security program. This is why NIST 800-53 is relevant to penetration testers — it's often the reason a client's compliance program requires a pentest in the first place.

Example for Understanding

Imagine a government contractor must follow a long list of building safety codes (NIST 800-53). One of those codes specifically says: "You must have a fire drill every year" (this is like CA-8 — Penetration Testing). NIST itself isn't the fire drill; it's the rulebook that requires the fire drill to happen.

Best For

Enterprise jobs, government environments, compliance-driven security programs, and security consulting. Not something a CTF or bug bounty beginner needs to master immediately.

Lesson 7 · NIST SP 800-115

Easy Meaning

NIST SP 800-115 = "Testing Guide." A technical guide specifically about how to plan and conduct security testing and assessment.

Additional Research — What It Actually Covers

Unlike 800-53 (which is a catalog of controls), NIST SP 800-115 ("Technical Guide to Information Security Testing and Assessment") is much closer to an actual testing methodology. It describes review techniques (like documentation review and log review), target identification and analysis techniques (like network discovery and vulnerability scanning), target vulnerability validation techniques (like penetration testing and social engineering), and guidance on security testing planning, execution, and post-testing activities including reporting.

Example for Understanding

If NIST 800-53 is the rulebook saying "you must do a fire drill," NIST 800-115 is the manual explaining exactly how to plan and run that fire drill properly — what to check beforehand, how to run it, and what to document afterward.

Best For

Government and enterprise-aligned penetration testing engagements, and understanding the formal structure behind security assessments in regulated industries.

Lesson 8 · OSSTMM

Easy Meaning

OSSTMM = "Roadmap." A general, high-level penetration testing methodology.

Additional Research — What Makes OSSTMM Different

The Open Source Security Testing Methodology Manual (OSSTMM) is a peer-reviewed methodology that focuses on measuring "operational security" across different channels — human, physical, wireless, telecommunications, and data networks. Rather than only listing test cases, OSSTMM introduces the idea of measuring security scientifically, using metrics like the RAV (Risk Assessment Values), to produce a comparable, repeatable security score rather than just a list of found vulnerabilities.

Example for Understanding

Think of OSSTMM like a general map of a city, showing all the major districts you should visit (human security, physical security, network security, and so on) without listing turn-by-turn directions for every single street. It gives you the big picture and a way to measure how "secure" something is overall, rather than a detailed checklist for every individual test.

Best For

Understanding the big-picture structure of a security assessment. Good to read once as a beginner, but not something that needs to be mastered immediately for CTFs or bug bounty.

Lesson 9 · PTES (Penetration Testing Execution Standard)

Easy Meaning

PTES = "Detailed Manual." A detailed penetration testing execution guide with tools and techniques for every phase.

Additional Research — The Seven PTES Phases

PTES defines seven phases that map closely onto how a real engagement actually runs, and it goes further than OSSTMM by including specific technical guidance and recommended tools for each phase:

Pre-engagement Interactions

Intelligence Gathering

Threat Modeling

Vulnerability Analysis

Exploitation

Post Exploitation

Reporting

Example for Understanding

If OSSTMM is the general map of the city, PTES is the full GPS route with turn-by-turn directions — it doesn't just tell you the phases of an engagement, it tells you the mindset, common tools, and specific technical steps for each phase, from the very first client conversation all the way to the final report.

Best For

Learning to think like a professional penetration tester rather than randomly running tools. Extremely useful for structuring both CTFs and real client engagements from start to finish.

Lesson 10 · ISSAF (Information Systems Security Assessment Framework)

This is the last framework discussed in the lecture. ISSAF is quite old, but it is still included in the CompTIA PenTest+ objectives, so you should know what it is.

What is ISSAF?

ISSAF stands for Information Systems Security Assessment Framework. It is a framework that provides guidance for performing security assessments — think of it as another penetration testing guide.

Easy Example

Imagine you buy a book called "How to Inspect a House." The book tells you to inspect doors, windows, roof, electrical system, and plumbing. Similarly, ISSAF tells a penetration tester to assess different parts of an organization's security.

What Does ISSAF Cover?

ISSAF includes guidance for testing areas such as password security, firewall security, switch security, Intrusion Detection Systems (IDS), and host security.

Is ISSAF Still Modern?

The latest version is from 2006. The general methodology is still useful, but some specific tools and techniques may be outdated because technology has changed significantly since then.

Should You Ignore ISSAF?

No — because it is listed in the PenTest+ exam objectives, and you may see exam questions asking "What is ISSAF?" or "Which framework provides security assessment guidance?" So you should know its purpose, even though it is older.

Interview Question — Good Answer

"Although ISSAF is an older framework, it still provides useful security assessment guidance and is included in the CompTIA PenTest+ objectives, so penetration testers should be familiar with it."

Complete Comparison · All Frameworks Side by Side

Framework	Easy Meaning	Main Purpose
MITRE ATT&CK	Hacker Encyclopedia	Real-world attacker tactics and techniques
Atomic Red Team	Practice Scripts	Simulates MITRE ATT&CK techniques safely
OWASP Top 10	Top Web Risks	Most critical web application vulnerabilities
OWASP WSTG	Testing Guide	Step-by-step web application testing
NIST SP 800-53	Security Controls	Defines security controls (e.g., CA-8 Penetration Testing)
NIST SP 800-115	Testing Guide	Technical guide for security testing and assessment
OSSTMM	Roadmap	General penetration testing methodology
PTES	Detailed Manual	Detailed execution guide with tools and techniques
ISSAF	Old Framework	Security assessment framework, still relevant for PenTest+

Easy Memory Trick — The Penetration Testing Backpack

- **MITRE ATT&CK** → Learn how hackers attack.
- **Atomic Red Team** → Practice those attacks.
- **OWASP** → Test web applications.
- **NIST** → Follow security standards.
- **OSSTMM** → Follow a roadmap.
- **PTES** → Use the detailed manual.
- **ISSAF** → Keep the older assessment guide for reference and exam knowledge.

Professional Interview Answer

"It depends on the engagement. For web application testing, I use the OWASP Web Security Testing Guide (WSTG). For a complete penetration testing methodology, PTES provides detailed execution guidance, while OSSTMM offers a structured high-level methodology. I also map my attack simulations to MITRE ATT&CK to ensure they reflect real-world attacker behavior."

Beginner Roadmap · Which Standard to Learn First (CTF & Bug Bounty)

For a beginner focused on CTFs and bug bounty, it's not efficient to learn every standard deeply at once — each framework has a different purpose and a different priority level.

Recommended Priority Order

1. OWASP Web Security Testing Guide (WSTG) ★★★★★

Best for: Bug Bounty, Web Pentesting, CTF Web Challenges. Most bug bounty programs target web applications, and WSTG teaches how to test websites systematically — authentication, authorization, SQL Injection, XSS, CSRF, file upload, session management, and API testing. If your goal is HackerOne, Bugcrowd, YesWeHack, or Intigriti, this should be priority #1.

2. PTES ★★★★★

Best for: General penetration testing and CTF methodology. PTES teaches the full flow — pre-engagement, information gathering, threat modeling, vulnerability analysis, exploitation, post exploitation, and reporting. It helps you think like a professional penetration tester instead of randomly running tools.

3. MITRE ATT&CK ★★★★★☆

Best for: Advanced CTFs, Red Teaming, Active Directory. Helps you understand how real attackers think — attack chains, privilege escalation, persistence, lateral movement. Especially useful once you start Hack The Box, Pro Labs, and Active Directory or Red Team exercises.

4. Atomic Red Team ★★★★★☆

Learn this after MITRE ATT&CK. It lets you safely simulate attacker techniques in your own lab — very useful if you want to become a Red Teamer.

5. NIST ★★★★★☆

Important for enterprise jobs, government environments, compliance, and security consulting. Not something you need immediately for CTFs or bug bounty.

6. OSSTMM ★★★★★☆

Good methodology. Read it once later. No need to master it as a beginner.

7. ISSAF ★☆☆☆☆

Know what it is for the PenTest+ exam. Don't spend much time on it.

A Full Learning Path — Phase by Phase

Phase 1 (Foundation)

Linux, Networking, HTTP, Burp Suite, OWASP WSTG, PortSwigger Web Security Academy, TryHackMe.

Phase 2 (Core Pentest Skills)

PTES, Nmap, Gobuster, ffuf, SQLMap (after learning manual SQL injection first), Metasploit basics.

Phase 3 (Advanced / Red Team Groundwork)

MITRE ATT&CK, Active Directory, Windows Privilege Escalation, Linux Privilege Escalation, Pivoting.

Phase 4 (Red Team Operations)

Atomic Red Team, Adversary Emulation, Red Team Operations.

Final Recommendation Summary

If you can choose...	Learn this
Only one framework today	OWASP WSTG
Two frameworks	OWASP WSTG + PTES
The full elite Red Team path	OWASP WSTG → PTES → MITRE ATT&CK → Atomic Red Team → NIST

This order matches a beginner's current skill level and the platforms typically used along the way — TryHackMe, Hack The Box, PortSwigger Web Security Academy, and later HackerOne and Bugcrowd.

The Full Keyword List

Methodology	MITRE ATT&CK
Atomic Red Team	OWASP Top 10
OWASP WSTG	NIST 800-53
NIST 800-115	OSSTMM
PTES	ISSAF
RAV	CA-8

Homework (10 minutes)

Without looking at your notes, explain these topics in simple English, in your own words:

- Why a methodology matters more than knowing individual tools
- The difference between OWASP Top 10 and OWASP WSTG
- The difference between NIST SP 800-53 and NIST SP 800-115
- Why OSSTMM is a "roadmap" while PTES is a "detailed manual"
- Why ISSAF is still worth knowing even though it's outdated
- Your own priority order for learning these frameworks, based on your CTF and bug bounty goals

If you can teach these topics to someone else in simple English, you have truly understood them. Get some rest — you've earned it.